

HALCYON COMMERCE LTD

TRUST & COMPLIANCE · STOREFRONT AND CHECKOUT

Storefront Control Requirements

Payment page security, price transparency, consumer contract rights, accessibility, review integrity and data protection across the UK and EU storefronts.

ILLUSTRATIVE EXAMPLE — NOT AN OFFICIAL TEXT

This document is an **authored illustrative example**, produced to demonstrate automated requirement generation and test design. Halcyon Commerce Ltd is a fictional retailer. The document control block, ownership, reference numbers and revision history are invented.

It is **not** a copy, extract or reproduction of any payment card industry standard, statute, statutory instrument, technical standard or regulator guidance, and it is not legal or compliance advice. Citations are given so that the reader can consult the official source directly. Positions stated here were compiled on 25 September 2026 and are not maintained.

Do not rely on this document for any compliance purpose.

Document reference	HAL-CR-2026-019
Version	1.5
Status	Approved for delivery use
Classification	Internal — Controlled
Document owner	Head of Trust and Compliance
Technical owner	Lead Engineer, Checkout
Effective from	1 October 2026
Next scheduled review	31 January 2027, or on any change to the validation route or the EU-facing storefront
Applies to	Product listing and detail pages, basket, checkout and payment pages, order confirmation and confirmation email, the customer account area, the review service, and the promotional pricing engine, on both the UK and EU storefronts

1. Purpose and scope

This document covers the six regimes that determine how the storefront must behave. Three of them bite at the two most sensitive points in the journey — the payment page, where card data is entered, and the price, which the customer relies on to decide. The other three reach the whole journey: whether a disabled customer can complete it, what the customer is contractually entitled to afterwards, and what personal data may be collected on the way.

Halcyon is established in the United Kingdom and sells to customers in the United Kingdom and in the European Union. That single fact drives the jurisdiction analysis in section 4, and it is the reason this document cannot be read as one undivided rule set.

In scope: every page in the purchase journey from listing to order confirmation, the confirmation email, the returns and cancellation path, the account area, the scripts executing on those pages, the price displayed at each step, the review display and submission paths, and the promotional pricing configuration.

Out of scope: the warehouse and fulfilment systems, the marketplace seller onboarding flow, and the corporate site.

2. Regulatory basis

Instrument	Citation	Binds	Status and dates that govern delivery
Payment card data security standard	PCI DSS version 4.0.1	Both	Current version, published 11 June 2024. Version 4.0 retired 31 December 2024; version 3.2.1 retired 31 March 2024. A request for comments on a future revision ran from 3 June to 20 July 2026; no successor had been published at compilation.
Payment page script and tamper requirements	Requirements 6.4.3 and 11.6.1	Both	Best practice until 31 March 2025; mandatory from 31 March 2025 . Version 4.0.1 did not move that date. The January 2025 revision of self-assessment questionnaire A removed them from that questionnaire and added an eligibility criterion on script susceptibility; frequently asked question 1588, effective 1 April 2025, limits that criterion to embedded inline frames.
Consumer protection from unfair trading	Digital Markets, Competition and Consumers Act 2024, Part 4 Chapter 1 and Schedule 20	UK	Commenced 6 April 2025 by SI 2025/272, excluding sections 232, 234 and 235. Revoked the 2008 unfair trading regulations. It did not replace the Consumer Rights Act or the Consumer Contracts Regulations, which continue in force alongside it.

Instrument	Citation	Binds	Status and dates that govern delivery
Subscription contracts	Digital Markets, Competition and Consumers Act 2024, Part 4 Chapter 2	UK	Not commenced. Absent from both commencement instruments. An intention to commence in January 2027 was announced in August 2026. An announced intention, not a legal date.
Price and unit price display	Price Marking Order 2004, as amended by SI 2024/1055 and SI 2025/592	UK	The 2024 amendments were originally to apply from 1 October 2025; SI 2025/592 deferred them to 6 April 2026 . Applies to online sales as well as physical premises.
Distance contract information and cancellation	Consumer Contracts (Information, Cancellation and Additional Charges) Regulations 2013, SI 2013/3134	UK	In force 13 June 2014. The most testable regime in this document: it dictates what must appear on screen, in what order, and what the order button may say.
Statutory rights in goods and unfair terms	Consumer Rights Act 2015	UK	In force 1 October 2015. Governs the remedies the returns policy must offer and the terms the contract may not contain.
Accessibility of e-commerce services	Directive (EU) 2019/882 (European Accessibility Act)	EU	Transposition deadline 28 June 2022; applies from 28 June 2025 . Transitional arrangements under Article 32 continue to 28 June 2030 for products already lawfully in use, and for service contracts concluded before 28 June 2025 for up to five years.
Accessibility technical standard	EN 301 549 version 4.1.1 (2026-09)	EU	Adopted 24 August 2026. Its predecessor referenced the 2.1 guidelines; version 4.1.1 references WCAG 2.2 . See the caution in section 3: it is a technical standard, not law, and confers no presumption of conformity under the Accessibility Act.
UK accessibility duty	Equality Act 2010, sections 20 and 29	GB	In force. An anticipatory duty to make reasonable adjustments for service providers. No technical standard is mandated. Does not extend to Northern Ireland, where separate legislation applies.
Electronic marketing and storage on terminal equipment	Privacy and Electronic Communications Regulations 2003, regulations 6 and 22, as amended	UK	New storage and access exceptions took effect 5 February 2026. Regulator guidance on storage and access dated 29 April 2026.
Data protection	UK GDPR and the EU General Data Protection Regulation	Both, divergently	Both in force. The divergence that matters on a storefront is the analytics and appearance exceptions in the UK storage rules, which have no EU equivalent.

3. Corrections

Nine claims in common circulation are wrong at the compilation date. They are set out here because each of them, if believed, produces either a control that tests nothing or a gap that

nobody notices.

Pricing and payment.

The unit pricing amendments **did not commence in October 2025**; they were deferred to 6 April 2026. The subscription rules **are not in force**. **Not all** of the 2024 consumer Act commenced in April 2025 — the private redress provisions were expressly excluded. Unit pricing and the mechanics of displaying a reduction **are not obligations of that Act**; they belong to the Price Marking Order and are enforced by trading standards.

Accessibility. These four are the most consequential in this document.

The Accessibility Act does apply to this business. The claim that it cannot reach a United Kingdom company is wrong. The trigger in Article 3(4) is providing, or offering to provide, the service to consumers in the Union. Where the business is established is not the test.

EN 301 549 confers no presumption of conformity under the Accessibility Act. This is asserted almost universally and is incorrect. No harmonised standard had been cited in the Official Journal under Directive (EU) 2019/882 at the compilation date. The standard's earlier citations sit under the separate public sector web accessibility directive. The practical effect is the opposite of reassuring: the Annex I duty applies in full, and there is no safe harbour to shelter under. Meeting the standard remains the sensible engineering target; it is simply not a legal presumption.

28 June 2025 was the application date, not the transposition deadline. Transposition was due 28 June 2022.

No United Kingdom statute requires a private retailer's website to meet a specific accessibility level. The 2018 public sector accessibility regulations bind public sector bodies and expressly not private businesses. The UK duty is the reasonable adjustments duty, which is about process and outcome rather than a conformance score.

Returns and refunds.

“Fourteen days from purchase to return” is wrong: the customer has fourteen days to *cancel*, usually running from delivery, and a further fourteen days to *send the goods back*. “Refund within thirty days” is wrong: thirty days is the default *delivery* period under the Consumer Rights Act; the refund period is fourteen days.

4. Jurisdiction: which obligations follow the customer

The controls in this document divide into three groups, and confusing them is the most likely source of a false pass in the test suite.

Group	Regimes	How scope is decided
Follows the card	PCI DSS	Applies wherever card payments are accepted, on both storefronts, regardless of customer location. Scope is decided by the payment architecture, not by geography.

Group	Regimes	How scope is decided
Follows the company	Consumer Rights Act; Consumer Contracts Regulations; Price Marking Order; DMCC Act; Equality Act	United Kingdom law applying to Halcyon's UK trading. The Equality Act duty covers Great Britain only.
Follows the customer	European Accessibility Act; EU General Data Protection Regulation and the EU storage rules	Engaged by offering the service to consumers in the Union. A UK company with no EU establishment is still caught.

The third group is the one teams get wrong, because nothing in the codebase announces it. The determination is made by product and commercial decisions — adding an EU country to the delivery list, quoting prices in euro, serving an EU-language storefront — any one of which can bring a whole regime into scope without a line of compliance code changing. Control ACC-01 exists to detect that, and it should run on every release.

A note on the microenterprise exemption. The Accessibility Act exempts service providers with fewer than ten persons and either turnover or a balance sheet total at or below two million euro. Halcyon exceeds both limbs and cannot rely on it. The exemption is recorded here only so that nobody reaches for it in a review.

5. Validation route and its effect on payment scope

Which payment controls the business must validate against depends on how the payment page is implemented. This determines the evidence the acquirer will ask for, and it is the single most consequential architectural decision in this document.

Implementation	Card data touches merchant origin	Script requirements in the questionnaire	Practical position
Full redirect to the provider	No	Not in questionnaire A	The script criterion in the January 2025 revision does not apply to redirects.
Embedded inline frame from the provider	No, if correctly implemented	Not in questionnaire A, but the eligibility criterion on script susceptibility applies	Halcyon's current implementation. The criterion must be satisfied and evidenced.
Fields hosted on the merchant page	Yes	Requirements 6.4.3 and 11.6.1 apply in full	Out of questionnaire A entirely; a different and substantially larger validation set applies.

The requirements do not disappear. Removing 6.4.3 and 11.6.1 from a self-assessment questionnaire changed the validation document, not the standard. The underlying requirements remain in the standard for e-commerce merchants, and the entity that accepts the compliance submission decides what validation it wants. Halcyon implements the script inventory, authorisation, integrity and tamper-detection controls regardless of which questionnaire applies, because doing so is also the most direct way to satisfy the eligibility criterion.

6. Part A — payment page security

PS-01 Inventory of every script on the payment page

PCI DSS 4.0.1 requirement 6.4.3

An inventory of all scripts must be maintained, with written justification for why each is necessary.

ACCEPTANCE CRITERIA

Enumerate every script that executes on the checkout and payment pages, including those injected dynamically and those loaded by other scripts. Every distinct script resolves to an entry in the inventory carrying a justification. A script executing that is absent from the inventory is a failure. Enumeration must capture fourth-party scripts, that is, scripts a third-party script loads in turn, because those are the common skimming vector and they do not appear in the page source.

PS-02 Every script is authorised

PCI DSS 4.0.1 requirement 6.4.3

A method must be implemented to confirm that each script is authorised.

ACCEPTANCE CRITERIA

Every executing script resolves to a host on the authorisation list. A script loaded from an unlisted origin is a failure, whether it executed successfully or not. Adding a script to the page without adding its origin to the list causes the check to fail, which is the behaviour that makes the control useful.

PS-03 Integrity of every script assured

PCI DSS 4.0.1 requirement 6.4.3

A method must be implemented to assure the integrity of each script.

ACCEPTANCE CRITERIA

Each externally hosted script carries a subresource integrity attribute with a matching cross-origin attribute, or is covered by an equivalent documented integrity mechanism recorded in the inventory. The integrity hash is verified against the fetched body: a stale hash that no longer matches the served file fails. A script with neither an integrity attribute nor a recorded alternative fails.

PS-04 Content security policy constrains script sources

Internal delivery standard, supporting requirement 6.4.3

A restrictive content security policy is the mechanism Halcyon uses to authorise scripts on the payment page.

ACCEPTANCE CRITERIA

The payment page response carries a content security policy header with an explicit script source directive that permits neither inline script, nor evaluated script, nor a wildcard source. A report-only policy does not satisfy this control. *This control is a Halcyon implementation choice. The standard does not name content security policy as a requirement, and it must not be presented as one.*

PS-05 Tamper detection on payment page content

PCI DSS 4.0.1 requirement 11.6.1

A change and tamper detection mechanism must alert personnel to unauthorised modification, including indicators of compromise, changes, additions and deletions, to the content of payment pages as received by the consumer browser.

ACCEPTANCE CRITERIA

In a test environment, inject an unauthorised script element into the payment page and assert that an alert is raised within the defined service level and recorded in the alerting system. Assert separately for an addition, a modification and a deletion, since a mechanism that detects additions but not deletions satisfies only part of the requirement. The detection must operate on the page as received by the browser, so a server-side file integrity check alone does not satisfy it.

PS-06 Tamper detection on payment page headers

PCI DSS 4.0.1 requirement 11.6.1

The same mechanism must cover the HTTP headers of the payment page.

ACCEPTANCE CRITERIA

Removing or altering a security-relevant response header in test raises an alert. A baseline header set is asserted present and unchanged on every scheduled run. Headers are explicitly named in the requirement, and a content-only mechanism fails this control.

PS-07 Detection frequency

PCI DSS 4.0.1 requirement 11.6.1, with requirement 12.3.1

The mechanism must evaluate the received headers and page content at the required frequency, being at least once every seven days or a frequency determined by a documented targeted risk analysis.

ACCEPTANCE CRITERIA

Query the monitoring evaluation log for each payment page location: the maximum interval between consecutive evaluations does not exceed seven days, or the interval set by the current risk analysis where one exists. A gap exceeding the applicable interval is a failure. Where a risk analysis sets the frequency, that analysis must be current, and an expired analysis returns the requirement to the seven-day default.

PS-08 No card data reaches the merchant origin

Questionnaire A eligibility criteria; frequently asked question 1588

Under the questionnaire the business validates against, no account data may be stored, processed or transmitted by merchant systems.

ACCEPTANCE CRITERIA

Capture the full network trace across the checkout journey. No request to a Halcyon-controlled host carries a card number or verification value in any body, query string, header, cookie or beacon. The card entry fields are demonstrably inside the provider's frame. A single analytics beacon carrying a form field value invalidates the eligibility criterion as well as failing this control, so the assertion covers analytics and error-reporting traffic, not only the checkout endpoints.

PS-09 Transport security

PCI DSS 4.0.1 requirement 4.2.1

Strong cryptography and security protocols must safeguard account data during transmission over open public networks, using only secure configurations and valid, unexpired, unrevoked certificates.

ACCEPTANCE CRITERIA

The checkout and payment hosts negotiate only current protocol versions; legacy protocol versions are refused. No null, export-grade or known-weak cipher suite is offered. The leaf certificate validates to a trusted root, is not revoked, and has more than fourteen days remaining. A plain unencrypted request to a checkout path redirects permanently to the secure scheme, and a strict transport security header is present.

PS-10 No mixed content in the purchase journey

PCI DSS 4.0.1 requirement 4.2.1

No part of the payment journey may load a resource over an unencrypted channel.

ACCEPTANCE CRITERIA

No form action, script source, style source, image source or fetch target in the checkout journey uses an unencrypted scheme. Assert on the network trace rather than on the browser's mixed-content warning, because a blocked request still indicates a defect in the page.

PS-11 Sensitive authentication data not retained

PCI DSS 4.0.1 requirement 3.3.1

Sensitive authentication data must not be retained after authorisation, even if encrypted, and must be rendered unrecoverable on completion of authorisation.

ACCEPTANCE CRITERIA

After a successful test authorisation, the test verification value appears nowhere in the confirmation page markup, the order API response, application logs, or any persisted order record. Search for the literal test value across all of them. A single log line is a failure.

PS-12 No card data persisted in the browser

PCI DSS 4.0.1 requirements 3.3.1 and 3.3.2

Card data must not persist on the client after authorisation.

ACCEPTANCE CRITERIA

After authorisation, the test card number and verification value are absent from local storage, session storage, cookies, indexed database storage and any hidden form field on the confirmation page. The check runs after navigation to confirmation, not before it, because the failure mode is data left behind by a completed flow.

PS-13 Card number masking on display

PCI DSS 4.0.1 requirement 3.4.1

Where a card number is displayed, it must be masked so that only the issuer identification number and the last four digits are visible, except to personnel with a legitimate business need.

ACCEPTANCE CRITERIA

On order confirmation, order history, emailed receipts and the standard back-office order view, any rendered card number matches the permitted mask. A full card number rendered to a role without an established need is a failure. Test by pattern: any sequence of thirteen to nineteen digits passing the check-digit algorithm appearing in the rendered output is treated as an unmasked card number.

PS-14 Password strength on customer and administrative accounts

PCI DSS 4.0.1 requirement 8.3.6

Passwords must be at least twelve characters and contain both numeric and alphabetic characters.

ACCEPTANCE CRITERIA

An eleven-character password is rejected. A twelve-character password containing only letters is rejected. A twelve-character password containing both letters and digits is accepted. Test registration, password change and password reset paths separately, since validation is often implemented in only one of them.

PS-15 Multi-factor authentication on administrative access

PCI DSS 4.0.1 requirement 8.4.2

Multi-factor authentication is required for all non-console access into the cardholder data environment, for any role and from any location.

ACCEPTANCE CRITERIA

Authenticating to the back office with a valid username and password alone presents a second factor challenge and grants no session until it is satisfied. There is no exemption for an internal network origin, a trusted device, or a service account used interactively.

PS-16 Authorisation on every data-bearing endpoint

PCI DSS 4.0.1 requirement 8.3.1

All user access to system components must be authenticated.

ACCEPTANCE CRITERIA

Order, customer and administrative endpoints return an authentication or authorisation failure when called unauthenticated and when called with a session belonging to a different customer. Substituting another customer's order identifier must not return that order. This case is asserted explicitly because it is the most common way order data leaks from an otherwise correct storefront.

7. Part B — price transparency

PR-01 The headline price is the total price

DMCC Act 2024 section 230(2)(b) and 230(4)

An invitation to purchase must give the total price, which includes any fees, taxes, charges or other payments the consumer will necessarily incur. A charge is mandatory if the consumer cannot buy the advertised product without paying it.

ACCEPTANCE CRITERIA

Record the price shown on the listing and detail pages, then complete checkout to the final payable amount. The final amount exceeds the headline only by charges the test explicitly chose. Any charge that could not be declined at any step must already be in the headline. This is the control the first enforcement decision under the regime turned on.

PR-02 No charge appears later in the journey

DMCC Act 2024 section 230(2)(b); price transparency guidance

Showing a headline price and introducing additional mandatory charges as the consumer proceeds is prohibited.

ACCEPTANCE CRITERIA

Capture the running total at every step: detail page, basket, delivery selection, payment, confirmation. The total is unchanged except where the test selected an option. A fee appearing at the payment step that was absent from the basket is a failure even if it is disclosed clearly at that point.

PR-03 Components never shown without a total

DMCC Act 2024 section 230(2)(b); price transparency guidance

Presenting the component parts of a price without giving the overall total is generally prohibited.

ACCEPTANCE CRITERIA

Wherever price components are displayed, a single explicit total appears in the same block. A block showing an item price and a fee with no stated sum is a failure.

PR-04 Calculation method given with equal prominence

DMCC Act 2024 section 230(2)(c) and 230(5); price transparency guidance

Where the total cannot be calculated in advance, the manner of its calculation must be given, with as much prominence as the price information, positioned immediately above, below or next to the calculable part of the price.

ACCEPTANCE CRITERIA

For a product with a variable charge, the calculation statement is in the same container as the price element, and its computed font size and colour contrast are not less than those of the price. A statement in a tooltip, behind an expander, in a footnote, or elsewhere on the page fails.

PR-05 The total is visible without interaction

DMCC Act 2024 section 230(9); price transparency guidance

Information provided in a manner that is unclear, unintelligible, ambiguous or untimely is treated as omitted.

ACCEPTANCE CRITERIA

The total price element is within the viewport without hovering, expanding, or scrolling past the primary call to action, at both a narrow mobile width and a desktop width. A total revealed only on interaction fails.

PR-06 Delivery treated correctly according to whether it can be declined

DMCC Act 2024 section 230(2)(g); price transparency guidance

Delivery is mandatory, and therefore part of the total price, where the consumer cannot arrange their own collection or delivery.

ACCEPTANCE CRITERIA

Where no collection option exists, the advertised price already includes the standard delivery charge. Where collection exists, delivery appears as a separate line that can genuinely be declined, and declining it completes an order. A non-declinable delivery fee added after the headline price is a failure.

PR-07 Optional extras are unselected and removable

Consumer Contracts Regulations 2013 regulation 40; price transparency guidance

Express consent is required for any payment additional to the main contract price, and consent cannot be inferred from a default. Presenting a charge separately, or describing it as an extra service, does not make it optional.

ACCEPTANCE CRITERIA

Every add-on presented as optional is unselected by default, and an order completes with it deselected. A pre-ticked option is a failure. Where a charge was taken without express consent the customer is entitled to have it back, so the control is also asserted against the refund path. A pre-ticked recycling or packaging charge is the pattern that drew the second enforcement decision in this area.

PR-08 Reference price claims are supported by actual selling history

DMCC Act 2024 sections 225 and 226

A practice is unfair if it gives false information, or is likely to deceive, as to price, the manner in which a price is calculated, or the existence of a specific price advantage, and causes a transactional decision the consumer would not otherwise take.

ACCEPTANCE CRITERIA

For every product showing a previous price or saving, the claimed previous price is present in the product's own pricing history as a price actually charged. A claim referencing a price never charged is a failure. *The length of time for which the previous price must have applied is not asserted here; see open item OI-04.*

PR-09 Countdown and urgency claims are true

DMCC Act 2024 Schedule 20, banned practice concerning false limited availability

Falsely stating that a product will be available only for a limited time, or on particular terms for a limited time, in order to elicit an immediate decision, is banned in all circumstances.

ACCEPTANCE CRITERIA

Let a countdown expire without interaction. The offer must actually end: the price changes or the offer is withdrawn. Reloading the page must not reset the timer to its starting value. A per-session timer that restarts on each visit is a failure.

PR-10 Advertised offers are actually purchasable

DMCC Act 2024 Schedule 20, banned practices concerning bait advertising

Inviting purchase at a specified price while being unable to supply at that price in reasonable quantities for a reasonable period, or then refusing to take orders for it in order to promote a different product, is banned.

ACCEPTANCE CRITERIA

Every product advertised at a promotional price on a listing page can be added to the basket and bought at that price while the promotion is live. Adding it must not yield a higher price, an out-of-stock state, or a redirect to a different product.

PR-11 Anything described as free costs nothing

DMCC Act 2024 Schedule 20, banned practice concerning free claims

Describing a product as free, gratis or without charge is banned where the consumer must pay anything beyond the unavoidable cost of responding and of collection or delivery.

ACCEPTANCE CRITERIA

Adding an item described as free does not increase the basket total. Free delivery adds no handling or processing charge. A free item that attaches a mandatory fee is a failure.

PR-12 Unit price displayed where required

Price Marking Order 2004 articles 4 and 5, as amended by SI 2024/1055, in force 6 April 2026

Where required, both the selling price and the unit price must be displayed, unambiguous, easily identifiable and clearly legible. The selling price is the final price for a unit of the product including all taxes, excluding any deposit.

ACCEPTANCE CRITERIA

Every product in a category requiring unit pricing shows both a selling price and a unit price on the listing and detail pages. The unit price uses the correct statutory unit and is derived from the price excluding any deposit. A unit price computed from a deposit-inclusive figure is a failure even where the arithmetic is otherwise correct.

PR-13 Multiple prices each carry their own unit price and conditions

Price Marking Order 2004 article 7A, as inserted by SI 2024/1055, and article 9 as amended by SI 2025/592

Where a product is offered at more than one price, each selling price and each unit price must be displayed with the conditions attaching to it, prominently and legibly.

ACCEPTANCE CRITERIA

For a member or loyalty price alongside a standard price, both prices and both unit prices render, and the condition attaching to the member price is stated next to it. Neither price is given visual prominence over the other: computed font size and weight are compared. Showing a single unit price for two prices is a failure.

8. Part C — distance contract information and cancellation

This is the most directly testable regime in the document. It dictates what must appear on screen, at which step, and what the order button may be called. One of its controls, CCR-03, carries a consequence no other control in this document carries.

CCR-01 Pre-contract information before the consumer is bound

Consumer Contracts Regulations 2013 regulation 13(1)(a) and Schedule 2

The trader must give or make available the information listed in Schedule 2 in a clear and comprehensible manner, in a way appropriate to the means of distance communication, before the consumer is bound.

ACCEPTANCE CRITERIA

Each Schedule 2 item is retrievable from the storefront before the pay step: main characteristics, trader identity, geographic address and contact details, total price including taxes, delivery charges, payment and delivery arrangements and the time for delivery, the conditions, time limit and procedure for cancelling, who bears the cost of return, the legal conformity duty, any guarantees, and the duration of the contract. A missing item is a failure.

CCR-02 Prominent restatement directly before the order

Consumer Contracts Regulations 2013 regulation 14(2)

Specified items must be given prominence directly before the consumer places the order.

ACCEPTANCE CRITERIA

On the final review step, the main characteristics, the total price including taxes and delivery, and the contract duration are visible on the same screen as the order button, without scrolling past it and without opening an accordion. Information reachable only by following a link does not satisfy this control.

CCR-03 Order button labelling

Consumer Contracts Regulations 2013 regulation 14(3) and 14(4)

The trader must ensure the consumer explicitly acknowledges that the order implies an obligation to pay. Where placing the order entails activating a button, that button must be labelled “order with obligation to pay” or a corresponding unambiguous formulation.

ACCEPTANCE CRITERIA

The final submit control's *accessible name* matches the approved list: “Order with obligation to pay”, “Pay now”, “Buy now”, “Confirm and pay”. It must fail on “Continue”, “Submit”, “Complete order”, “Confirm” and “Register”. Assert on the rendered accessible name including any label attribute, not on the visible text alone, because a button reading “Pay now” with an accessible label of “Continue” fails for a screen reader user.

CCR-04 Consequence of a non-compliant order step

Consumer Contracts Regulations 2013 regulation 14(5)

If the trader has not complied with the acknowledgement and labelling requirements, the consumer is not bound by the contract or the order.

ACCEPTANCE CRITERIA

CCR-03 is classified as a blocking defect. A failing button label means every order placed through that flow is unenforceable, so no compensating control and no risk acceptance passes this. This is the only control in the document whose failure invalidates completed transactions rather than creating an exposure.

CCR-05 Delivery restrictions and payment methods stated at the start

Consumer Contracts Regulations 2013 regulation 14(6)

Trading websites must indicate clearly and legibly, at the latest at the beginning of the ordering process, whether any delivery restrictions apply and which means of payment are accepted.

ACCEPTANCE CRITERIA

Delivery restriction text and the accepted payment methods are present on the basket page, which is the first step of ordering. First revealing either at the payment step is a failure.

CCR-06 Confirmation on a durable medium

Consumer Contracts Regulations 2013 regulation 16

Confirmation of the contract must be given on a durable medium, containing all Schedule 2 information not already so given, within a reasonable time and at the latest by the time the goods are delivered.

ACCEPTANCE CRITERIA

A confirmation email carrying the full Schedule 2 set, including cancellation rights, is dispatched at order placement. A confirmation available only inside the logged-in account area is a failure, because it is not a durable medium. A confirmation sent after the parcel arrives is a failure on timing.

CCR-07 Model cancellation form provided

Consumer Contracts Regulations 2013 regulation 13(1)(b) and Schedule 3 Part B

Where a right to cancel exists, the trader must give or make available a cancellation form in the prescribed form.

ACCEPTANCE CRITERIA

The form is linked from the confirmation email and from the returns page, and is reachable without logging in. The obligation is to provide it; the customer is not required to use it, so a returns flow that refuses a cancellation made by other means also fails.

CCR-08 Cancellation period and its five start points

Consumer Contracts Regulations 2013 regulation 30(2) to (6)

The fourteen-day period runs from the day the contract is entered into for services and digital content, and from the day the consumer or their nominee takes physical possession for goods. For an order of several goods delivered separately it runs from the last item; for goods delivered in lots, from the last lot; for regular deliveries over a period, from the first delivery.

ACCEPTANCE CRITERIA

The returns eligibility calculation implements all five start points. A single rule of fourteen days from the order date applied to goods is a failure. A split shipment whose clock starts on the first parcel is a failure. Delivery to the carrier is not possession; the clock starts on delivery to the customer.

CCR-09 Extension where cancellation information was not given

Consumer Contracts Regulations 2013 regulation 31(1) to (3)

Where the required cancellation information was not provided, the period is extended: if the information is supplied within twelve months, it ends fourteen days after receipt; otherwise it ends twelve months after the day it would otherwise have ended.

ACCEPTANCE CRITERIA

The returns system can accept a cancellation up to twelve months and fourteen days after the normal end date where there is no evidence the information was supplied. A hard fourteen-day cut-off with no exception path is a failure.

CCR-10 Refund within fourteen days, to the original payment method

Consumer Contracts Regulations 2013 regulation 34(5) to (8)

Where the trader has not offered to collect the goods, reimbursement is due within fourteen days of receiving the goods back or of the consumer supplying evidence of return, whichever is earlier. Reimbursement must use the same means of payment unless the consumer expressly agrees otherwise.

ACCEPTANCE CRITERIA

The interval between the refund and the earlier of goods-received and proof-of-postage does not exceed fourteen days. The refund is issued to the original payment instrument. Defaulting to store credit is a failure. Waiting for the parcel when proof of postage was supplied earlier is a failure.

CCR-11 Standard delivery cost refunded on cancellation

Consumer Contracts Regulations 2013 regulation 34(2) to (4)

The trader must reimburse delivery charges received, but need not reimburse the amount by which the consumer's chosen delivery exceeded the least expensive common and generally acceptable kind of delivery offered.

ACCEPTANCE CRITERIA

On a full cancellation the refund equals the item price plus the standard delivery charge. Refunding the item price alone is a failure. Where the customer paid for an express service, refunding the standard equivalent is correct and is asserted as such.

CCR-12 Return costs charged only where disclosed

Consumer Contracts Regulations 2013 regulations 13 and 35, with Schedule 2

The consumer bears the direct cost of returning the goods only if the trader informed them they would have to. Where that information was not given, the consumer is not to bear the cost.

ACCEPTANCE CRITERIA

If the returns policy charges for return postage, the corresponding Schedule 2 statement is present both in the pre-contract information and in the confirmation under CCR-06. Charging for returns without both is a failure. The customer has fourteen days from notifying cancellation to send the goods back, and that window is applied separately from the cancellation window itself.

Statutory rights and contract terms

CRA-01 Product page information becomes a contract term

Consumer Rights Act 2015 section 11

Goods must match their description. Information provided under the distance selling rules about the main characteristics is treated as a term of the contract, and a change to it is not effective unless expressly agreed.

ACCEPTANCE CRITERIA

The attribute values shown on the product page match the record for the item actually shipped. A snapshot of the page at order time is retained and reconciles to the confirmation. Silent substitution to a different specification is a failure even where the replacement is equivalent or better.

CRA-02 Remedies for faulty goods correctly described and offered

Consumer Rights Act 2015 sections 19(3), 22, 23 and 24

The short-term right to reject runs for thirty days. Repair or replacement must be within a reasonable time, without significant inconvenience, at the trader's cost. Price reduction or the final right to reject arises after one failed repair or replacement, or where repair or replacement is impossible or not done in reasonable time. No deduction for use may be made in the first six months, other than for motor vehicles.

ACCEPTANCE CRITERIA

The faulty goods policy states thirty days, not fourteen. It states that repair and replacement are free. It states that one failed attempt unlocks the next remedy. It applies no restocking or usage deduction within six months. A policy offering only exchange or credit for faulty goods inside the thirty days is a failure.

CRA-03 Thirty-day default delivery

Consumer Rights Act 2015 section 28(3)

Unless otherwise agreed, the trader must deliver without undue delay and in any event not more than thirty days after the day the contract is entered into.

ACCEPTANCE CRITERIA

No product page or checkout offers a lead time longer than thirty days without an explicit agreed delivery date captured at the point of order. Backorder and pre-order items surface a specific date rather than an open-ended estimate.

CRA-04 Risk remains with the trader until physical possession

Consumer Rights Act 2015 section 29

The goods remain at the trader's risk until they come into the physical possession of the consumer or a person identified by the consumer. Risk passes on delivery to a carrier only where the carrier was commissioned by the consumer and was not among the options the trader offered.

ACCEPTANCE CRITERIA

The terms contain no clause passing risk or title on dispatch or on handover to a trader-offered carrier. Lost-in-transit cases resolve in the customer's favour by default. A dispatch-risk clause fails this control and also CRA-05.

CRA-05 Unfair terms, transparency and prominence

Consumer Rights Act 2015 sections 62, 64, 68 and 69, with Schedule 2 Part 1

An unfair term is not binding. A term is unfair if, contrary to good faith, it causes a significant imbalance to the consumer's detriment. Terms about the main subject matter or the price escape the fairness assessment only if they are transparent and prominent. All written terms must be transparent, and ambiguity is resolved in the consumer's favour.

ACCEPTANCE CRITERIA

The terms contain none of the indicative unfair terms: binding the consumer to terms they had no real opportunity to see, unilateral variation without a specified valid reason, setting or increasing the price after the consumer is bound without a right to cancel, or restricting access to legal remedies. Any recurring charge, auto-renewal or non-refundable fee is disclosed on the checkout screen itself; a hyperlink to the terms does not make a price term prominent. Terms render legibly at a normal reading size and contrast.

9. Part D — accessibility

ACC-01 determines whether the rest of this part applies at all. It is written first, and it is the only control in the document whose result changes the scope of other controls.

ACC-01 Scope trigger for the Accessibility Act

Directive (EU) 2019/882 Articles 2(2), 3(4) and 3(30)

A service provider is caught where it provides, or offers to provide, a service on the Union market to consumers in the Union. Establishment in the Union is not the test.

ACCEPTANCE CRITERIA

The storefront is in scope if any of the following is true: an EU country is selectable in the delivery address list; EU shipping rates are quoted at checkout; prices render in euro for an EU visitor; or an EU-language or EU-locale storefront is served. Where any is true, ACC-02 to ACC-07 must pass. This control runs on every release, because a commercial change such as adding a shipping destination brings the regime into scope without any compliance code changing.

ACC-02 The purchase journey is perceivable, operable, understandable and robust

Directive (EU) 2019/882 Annex I, Section III

Websites, including related online applications and mobile device-based services, must be made accessible in a consistent and adequate way by making them perceivable, operable, understandable and robust.

ACCEPTANCE CRITERIA

An automated and manual audit of the listing, detail, basket, checkout, account and confirmation pages returns no Level A or Level AA failures against the technical baseline. Every step of the purchase journey is completable using the keyboard alone, and using a screen reader. A journey that is auditable but not completable fails.

ACC-03 Accessibility information about the products sold is passed through

Directive (EU) 2019/882 Annex I, Section IV

Where the responsible economic operator provides accessibility information about a product, the e-commerce service must make that information available.

ACCEPTANCE CRITERIA

For any item whose supplier feed carries an accessibility attribute, the product page renders a visible accessibility section, present in the page markup and in structured data rather than only in a downloadable document. An attribute present in the feed and absent from the page is a failure.

ACC-04 Identification, security and payment functions are accessible

Directive (EU) 2019/882 Annex I, Section IV

Identification, security and payment methods used as part of the service must be perceivable, operable, understandable and robust.

ACCEPTANCE CRITERIA

Sign-in, password reset, any challenge-response test, card detail entry and the payment authentication step are each keyboard operable, carry programmatic labels and accessible names, announce errors to assistive technology, and are not trapped in an unlabelled frame. A challenge-response test with no non-visual alternative is a failure.

ACC-05 Embedded third-party payment flows meet the same bar

Directive (EU) 2019/882 Annex I, Section IV

The obligation covers identification methods, electronic signatures and payment services used in delivering the service, whoever supplies them.

ACCEPTANCE CRITERIA

Wallet, deferred payment and signature flows embedded in checkout pass the same keyboard and screen reader assertions as ACC-04. A hosted payment frame supplied by a third party that fails those assertions is still Halcyon's failure, and is raised against Halcyon rather than logged against the supplier and closed.

ACC-06 Information about the service is itself accessible

Directive (EU) 2019/882 Annex I, Section III

Information explaining how the service works, and its accessibility characteristics, must itself be perceivable, operable, understandable and robust.

ACCEPTANCE CRITERIA

An accessibility statement is reachable within two clicks from any page through a persistent link, is served as a web page rather than only as a downloadable document, describes the accessibility characteristics of the service, and gives a route for reporting an accessibility problem.

ACC-07 Support channels are accessible

Directive (EU) 2019/882 Annex I, Section III

Help desks, call centres and technical support must provide information on the accessibility of the service through accessible modes of communication.

ACCEPTANCE CRITERIA

At least one non-voice contact channel is offered, and any chat widget is keyboard reachable and labelled for assistive technology. Support available only by telephone is a failure.

ACC-08 Anticipatory reasonable adjustments

Equality Act 2010 sections 20 and 29

A service provider must take reasonable steps to avoid a provision, criterion or practice putting a disabled person at a substantial disadvantage, and to provide auxiliary aids. Where the duty concerns information, reasonable steps include providing it in an accessible format. The duty is anticipatory: it is owed before any individual complains.

ACCEPTANCE CRITERIA

Three artefacts exist: a completed accessibility audit of the purchase journey; a remediation backlog with owners and target dates; and an alternative route to complete a purchase where a barrier remains unresolved. The absence of all three is a failure. Because no technical level is legally mandated, the assertion is on the process and its evidence, with the technical baseline used as evidence of reasonableness rather than as the test itself.

ACC-09 Negative control: no United Kingdom statutory technical standard

Public Sector Bodies (Websites and Mobile Applications) Accessibility Regulations 2018, which apply to public sector bodies only

No United Kingdom statute requires a private retailer's website to meet a specified accessibility conformance level.

ACCEPTANCE CRITERIA

Any internal control, policy statement or customer-facing copy asserting that Halcyon is legally required in the United Kingdom to meet a named conformance level fails review and is corrected to the reasonable adjustments duty. This is a documentation control rather than a software one, and it exists because the incorrect claim is common and makes the real duty harder to discharge.

10. Part E — consumer review integrity

RV-01 No fake reviews published

DMCC Act 2024 Schedule 20, banned practice concerning consumer reviews

Submitting or commissioning fake consumer reviews, publishing reviews in a misleading way, and concealing that a review was incentivised are banned in all circumstances.

ACCEPTANCE CRITERIA

No published review maps to an account flagged as internal, staff or affiliate. Where reviews are badged as verified, every such review maps to a matching completed order. A review badged verified with no matching order is a failure.

RV-02 Incentivised reviews are labelled

DMCC Act 2024 Schedule 20; fake reviews guidance

Concealing that a review has been incentivised is banned.

ACCEPTANCE CRITERIA

Every review record carrying an incentive flag renders a visible disclosure on the review card. A flagged review rendering without the label is a failure, and the label must be present in the rendered output rather than only in the data.

RV-03 Reasonable and proportionate prevention steps are in place

DMCC Act 2024 Schedule 20; fake reviews guidance

A trader publishing consumer reviews must take steps that are reasonable and proportionate to prevent the publication of, and to remove, fake reviews and reviews concealing an incentive.

ACCEPTANCE CRITERIA

A published reviews policy page is reachable from the review display. A report control is present on every review card and returns an acknowledgement. A review submitted from an account with no matching order is either rejected or queued for moderation rather than published immediately. All three are asserted, because the obligation is about the process, not about any single review.

RV-04 Aggregate ratings reflect all published reviews

DMCC Act 2024 Schedule 20, publishing reviews in a misleading way

Suppressing genuine negative reviews, selecting favourable reviews for display, and merging reviews across distinct products are treated as misleading publication.

ACCEPTANCE CRITERIA

The displayed average equals the computed mean over the full published review set for that specific product, not over a filtered subset. Reviews for a different variant or a different product do not contribute. The default sort does not remove low-rated reviews from the first page without a visible filter state indicating that a filter is applied.

11. Part F — data protection on the storefront

The Group's general data protection controls are held separately. This part covers only what is decided in storefront code: what is collected at checkout, what is stored on the customer's device, and how consent is taken.

DP-01 Marketing consent is opt-in, unbundled and per channel

Privacy and Electronic Communications Regulations 2003 regulation 22; UK GDPR Articles 4(11) and 7

Consent requires a clear affirmative action. Pre-ticked boxes do not constitute consent, consent must be kept separate from other matters such as terms and conditions, and it must be sought separately for each type of marketing.

ACCEPTANCE CRITERIA

The marketing control is present, unchecked on load, separate from the terms acceptance and from the order button, and offered per channel. Any of the following is a failure: a pre-ticked box; consent bundled with the terms; consent implied by placing the order; or a single control covering several channels.

DP-02 The existing-customer exception and its limits

Privacy and Electronic Communications Regulations 2003 regulation 22(3)

Marketing without consent is permitted only where all three conditions are met: the contact details were obtained in the course of a sale or negotiations for a sale, the marketing concerns the trader's own similar products or services, and a simple means of refusing was offered at collection and in every subsequent message.

ACCEPTANCE CRITERIA

The exception flag is set only where an order or an abandoned-checkout negotiation record exists for that address. Newsletter-only sign-ups, competition entries and purchased lists are excluded, and a test asserting each of those is excluded must pass. Every marketing message carries a working unsubscribe and identifies the sender with a valid contact address.

DP-03 Storage on the customer's device, with the UK and EU split enforced

Privacy and Electronic Communications Regulations 2003 regulation 6; EU ePrivacy Directive 2002/58 Article 5(3)

Non-essential storage requires consent. The United Kingdom rules carry exceptions for statistical purposes and for appearance and preferences, each conditional on an objection mechanism being offered, and neither covers advertising or cross-site tracking. The EU rules carry no equivalent exception.

ACCEPTANCE CRITERIA

On a first load with no prior choice, the network trace shows no advertising or marketing tags and no cross-site identifiers. Reject is offered at the same level and click cost as accept, and no category toggle is pre-enabled. The jurisdiction assertion is the important one: for an EU visitor, analytics must also be blocked before consent; for a UK visitor, analytics may fire only where a free and simple objection control is exposed. A single consent platform tuned to the UK rules and serving EU visitors the same way is a failure.

DP-04 Data minimisation at checkout

UK GDPR and EU GDPR Article 5(1)(c)

Personal data must be adequate, relevant and limited to what is necessary for the purpose.

ACCEPTANCE CRITERIA

A checkout completes using only the fields necessary for a goods contract: name, delivery address, contact email and payment data, with a telephone number only where the carrier requires it and is labelled as such. Any of the following being mandatory without a purpose-specific justification is a failure: date of birth other than on an age-restricted item, where it must be conditional on that item; gender or title; marketing preferences; a second contact number; or company and tax details on a consumer order.

DP-05 Guest checkout available

UK GDPR and EU GDPR Articles 5(1)(c) and 6(1)(b)

Where the purchase is a one-off, the personal data necessary to perform the contract can be collected without requiring the customer to create an account, so a mandatory account is difficult to justify as necessary for performance.

ACCEPTANCE CRITERIA

A guest path completes a purchase end to end without creating a credentialled account. Where an account is offered, sign-up is a clearly separated optional step rather than a precondition of paying. *The supervisory position underlying this control was issued in draft; the control rests on the minimisation and necessity analysis rather than on that draft. See open item OI-10.*

DP-06 Retention tiering and self-service rights

UK GDPR and EU GDPR Articles 5(1)(e), 12(3), 15, 17, 20 and 21(2); company accounting record duties

Personal data must not be kept longer than necessary, while accounting records must be retained for six years from the end of the financial year to which they relate. The right to object to direct marketing is absolute.

ACCEPTANCE CRITERIA

A retention schedule distinguishes transaction and tax records, retained on a legal obligation basis, from marketing profiles, browsing history and abandoned basket data, which carry short justified periods. The account area exposes download, delete and marketing preference controls. An erasure request suppresses marketing and deletes the discretionary data while retaining the minimum tax record; a system that refuses erasure outright, or that deletes the tax record, fails either way. Requests are actioned within one month.

DP-07 Representative named for the EU-facing storefront

EU GDPR Articles 3(2)(a), 13(1)(a) and 27

A controller not established in the Union that offers goods to data subjects in the Union must generally designate a representative in the Union, whose identity must be given in the privacy information.

ACCEPTANCE CRITERIA

Where ACC-01 has determined the EU storefront is live, the privacy notice names a representative in the Union with contact details. Absence is a failure. This control is bound to the same trigger as ACC-01, so that adding an EU shipping destination raises both.

12. Open items

Item	Question	Disposition
OI-01	The verbatim wording of the payment requirements cited in Part A other than 6.4.3 and 11.6.1.	The standard is distributed under a licence acceptance and the full text was not retrieved. Verify the wording of requirements 3.x, 4.2.1 and 8.x against the official document before treating any quotation as exact.
OI-02	The precise formulation of the evaluation frequency in requirement 11.6.1.	Sources render it as at least once every seven days, or a frequency set by a targeted risk analysis. PS-07 asserts the interval, not the wording.
OI-03	A reported revision in August 2026 to the guidance on marking the payment page requirements as not applicable in a report on compliance.	Described consistently by two independent commentaries but not read on the official portal. If the validation route changes, confirm the current position with the acquirer.
OI-04	How long a previous price must have been charged for a saving claim to be supportable.	Neither the price transparency guidance nor the unfair practices guidance addresses reference pricing. PR-08 asserts that the price was actually charged and deliberately does not assert a qualifying period.
OI-05	The exact sub-paragraph numbering within Schedule 20 for the banned practices cited in Parts B and E.	The practices are identified by description rather than by paragraph number for that reason. Confirm the numbering before citing it externally.
OI-06	An update recorded against the fake reviews guidance page on 24 September 2026 whose content was not described.	One day before compilation. Re-read the guidance before relying on the detail in Part E.
OI-07	Whether a harmonised standard has since been cited in the Official Journal under the Accessibility Act, which would create a presumption of conformity.	None had been cited at compilation. Commentary predicting a citation date is not supported by a primary source. Re-check before relying on the position stated in section 3, and note that a citation would add a safe harbour rather than change the underlying duty.

Item	Question	Disposition
OI-08	The penalties provision of the Accessibility Act and the levels set by individual member states.	Not retrieved. Penalties are set nationally and vary. No figure is asserted anywhere in this document, and any circulated ceiling should be treated as unverified.
OI-09	Whether any member state imposed e-commerce accessibility requirements stricter than Annex I when transposing.	Not researched. A real residual risk for a retailer shipping into several member states. Assess per destination market before relying on Part D as complete.
OI-10	Whether the supervisory recommendations on mandatory user accounts have been finalised.	Adopted in draft for consultation in December 2025; consultation closed February 2026. Final status not confirmed. DP-05 does not rest on it.
OI-11	The Northern Ireland accessibility position.	The Equality Act does not extend to Northern Ireland, where separate legislation applies. Not researched. ACC-08 and ACC-09 are Great Britain only.
OI-12	The prescribed wording of the model cancellation form.	The obligation to provide it is confirmed; the prescribed text was not retrieved. Obtain it before publishing the form itself.
OI-13	Sign-off owner for regulatory references shown to customers or used in marketing.	Unassigned. Escalate before any external use.

13. Revision history

Version	Date	Change
1.0	2 April 2025	First issue, following the payment page requirements becoming mandatory and the consumer protection regime commencing.
1.1	29 April 2026	Unit pricing controls added following the deferred commencement on 6 April 2026.
1.2	11 May 2026	Total price controls strengthened after the first enforcement decision concerning an omitted booking fee.
1.3	2 July 2026	Pre-ticked option control added after the second enforcement decision.
1.4	25 September 2026	Corrections section added. Validation route section added after an internal review found the script requirements described as inapplicable rather than as moved out of the questionnaire.
1.5	25 September 2026	Scope extended beyond payment security and pricing: accessibility, distance contract information and cancellation, statutory rights, and storefront data protection added. Section 4 added after a review found no control detecting when a commercial change brings the EU regimes into scope. Four accessibility corrections added to section 3. Document renamed.

Halcyon Commerce Ltd is a fictional retailer and this document is an illustrative example produced for demonstration purposes. It is not an official standard, statute, technical standard or regulator guidance, and must not be relied on for any compliance purpose. Positions compiled 25 September 2026 and not maintained thereafter.